COLORADO
Information Security
Governor's Office of Information Technology

TS-DBS-006: Database Security

Document ID	TS-DBS-006
Title	Database Security
Executive Sponsor	Database Services Management, DBS Manager
Issuing Authority	Governor's Office of Information Technology (OIT)
Applies to	OIT and OIT supported agencies; employees of OIT, agencies supported by OIT, and vendors contracted by OIT or its stakeholders.
Instrument Type	Standard
Version	4.0
Effective Date	07-01-2025
Last Updated	07-01-2026

1. Purpose

OIT is statutorily mandated to provide IT support and services to the State and its stakeholders in the most effective and efficient manner possible (as defined by C.R.S. 24-37.5). To satisfy the stakeholder needs surrounding Database Security, the following is submitted as the standard for OIT Database Services to provide the service.

The purpose of this document is to communicate the standards that the Governor's Office of Information Technology (OIT) has developed with the intent of providing enterprise standard configurations for Database Security. Standards are based on a best-of-value decision assessment involving multifarious factors, such as stakeholder needs, hardware configurations that are serviced and supported by OIT, as well as operational and security best practices guidelines.

The ultimate purpose of the Database Security Standard is to describe the minimum requirements for designing, installing, securing, monitoring, maintaining, protecting, and any OIT supported DBMS environment.

Database security helps to ensure that stored information is only accessible to authorized users or administrators of that database environment. The OIT Database Services (DBS) team is the administrator of supported database environments and responsible for establishing and maintaining database security. The guiding principles for DBS are based on documentation from NIST (NIST SP:800-12) for all secure data access.

The purpose of this policy is to document the scope of responsibilities of DBS to ensure and maintain database security on DBS supported database platforms.

2. Scope

These standards apply to OIT and OIT supported agencies. This Standard shall be used by employees of OIT, agencies supported by OIT, and vendors contracted by OIT or its stakeholders, as a means to enforce technology standardization and assist in making the usage, support, and/or purchase of technologies more consistent and efficient.

Additionally, the standards assigned and prescribed by this document, instituted for use by the approval of the OIT Architecture Review Board (ARB), should be used to govern purchase and deployment decisions deemed as “go-forward” or “net-new” strategies or implementations, and are not intended for use as retroactively enforceable mandate or policy for immediate conformance (especially in cases where cost implications may be prohibitive).

Any/all standards are predicated with the assumption that there can be no point of enforcement unless and until there is an effort to re-procure, renew (contracts), reconfigure (including upgrades), or redevelop the system. At any time that a decision is made to make an investment of resources in sustaining or improving the system, conformance to existing standards should be part of the assessed level of effort for that investment activity. For guidance (or enforcement) in conformance to standards during any of these types of activities, an email request may be sent to OIT_OEA@state.co.us with the subject line “Request for Architecture Review: <projectName/systemName>”

For the purpose of enforcement, this standard is rated CAT 1 according to the Enforcement Category Chart.

3. Roles and Responsibilities

Enterprise Architecture - Chief Enterprise Architect

- Chairs and conducts business of the Architecture Review Board (ARB).
- Update effective date and/or last review date.
- Publish the ARB approved Standard to the OIT public facing website.

Architecture Review Board (ARB)

- Engage stakeholders and subject matter experts to determine standard.
- Review/Approve Standard (this document).

Database Services Management - DBS Manager

- Owner of Standard.
- Engage stakeholders and subject matter experts to determine standard.
- Update document standards and version number.
- Present to the Architecture Review Board for approval and adoption.

Additional Assignments

DBS Team

- Manages database user security on supported database platforms.
- Audits database activity in accordance with recommended security settings contained in the CIS database benchmark for the appropriate platform and version of database software.

Database User

- Requests access for only data or functionality required to perform their job duties.

All OIT staff are responsible to be aware of the existence of this (and all) standard(s) and its purposes of authority and governance in support of OIT's statutorily mandated mission in service of Colorado State Government affairs.

4. Standards

Database Management Responsibility

- DB Services is responsible for the comprehensive management of all database instances residing on a managed server. This includes routine maintenance, performance tuning, security patching, and ensuring high availability. Furthermore, any provisioning of new database instances on a managed server will require explicit approval and execution by DB Services.
- DBS will determine whether additional instances are required considering the justifications and manage all databases within all instances supported DB servers.

Database Administrative Privileges

- It is the policy of OIT DBS that only DBS Database Administrators will have full administrative privileges for all DBS supported database product installations.

Database Role Administration

- It is the policy of OIT DBS that Database users will be provided database access with roles administered by DBS based on the principle of least privilege as defined by CISO (Policy CISP-001).

Sensitive Data Platform Placement

- It is the policy of OIT DBS that sensitive data, as classified by the business (TS-CISO-001), will be placed in the appropriate secure platform supported by DBS.

Standard Database Auditing

- It is the policy of OIT DBS that standard database auditing will be implemented in all environments to the fullest possible extent of the requirements in compliance with CISP-003.
- Additional auditing may be implemented based on business and statutory requirements.

Data Masking and Redaction

- Data Masking and/or Data Redaction is encouraged and can be requested on all non-production databases containing data identified to be in a data classification including but not limited to PHI, PII, FTI, CJIS, HIPAA.
- An approved tool is required for all systems requiring data masking and/or redaction.

Database Encryption

- Encryption in transit is required on all database traffic using Transport Layer Security (TLS) version 1.2 or higher.

Database Patching and Upgrades

- All production databases will be patched to a version no more than two major releases behind the latest vendor release (N-2), following thorough testing, with critical security patches prioritized for testing and deployment within a shorter timeframe.

- All new provisioned databases must be at the current version supported as defined in TS-DBS-001: Supported Databases and Versions.
- Any database that can no longer be patched either must be upgraded to the latest supported version or an exception must be obtained from the affected agency.

Database Exceptions

- Any exceptions defined in the Database Security standard must be made in writing by the affected agency and kept on file with the Database Services team.

5. Compliance

All DBS team staff, and database users must comply with this policy in order to secure, access, store data, and maintain database servers. Non-compliance of this policy may result in corrective action.

6. Variance and Exception Process

Any request to procure or deploy technology that is a variance to the standards and provisions stated within this document must be requested of and approved by the "Owner of Standard" listed in Section 3 (Roles and Responsibilities) of this document.

Requests may be acquired by completing the "EXCEPTION REQUEST to Technical Standard" form and including the completed form (including all signatures) along with other documentation required as part of standard procedures when executing a technology procurement or service deployment.

7. References

OIT documents and policies

- CISP-001: Access Control
- Enforcement Category Chart
- TS-CISO-001: Data Security Categorization
- TS-INF-003: Identity and Access Administration
- Security Technical Implementation Guides (STIGs) – DoD Cyber Exchange
- NIST SP:800-12
- CISP-003 IT Audit Log Management & Accountability

8. Definitions

Standard: A rule that specifies a particular course of action or response to a given situation. Standards are mandatory directives to carry out management's policies and are used to measure compliance with policies. Standards serve as specifications for the implementation of policies and are designed to promote implementation of high-level organization policy rather than to create new policy in themselves.

DBS: OIT Database Services Team

SA: OIT System or Server Administration Team

CIS: Center for Internet Security

CISO: Chief Information Security Officer

NIST: National Institute of Standards and Technology Special Publication

STIG: Security Technical Implementation Guides as defined by disa.gov

Database Privileges: Environmental and/or data permissions that allow levels of access to data and database objects.

Database Binaries: Core software programs and source data used during the creation and operation of the database.

OEA (Office of Enterprise Architecture): The Office of Enterprise Architecture was formed as an office under OIT by Governor's Rule 8 CCR 1501-7.

OIT (Office of Information Technology): The Governor's Office of Information Technology was created and governed by C.R.S. 24-37.5, et seq.

Exception request: A document requesting an exception to a recognized standard, requiring a business or technical justification for granting the exception. Typically an exception request is subject to review and approval by an authority in the area.